CRISC Mixed Practice Exam – 100 Real-Life Questions

Weighted to the Four CRISC Domains – Practical Scenarios

CRISC Mastery Series

October 23, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Governance (26 percent of the exam)
2. Risk Assessment (20 percent of the exam)
3. Risk Response and Reporting (32 percent of the exam)
4. Information Technology and Security (22 percent of the exam)
5. Conclusion

Q1: Risk Committee Charter

Question

A newly formed risk committee has no written charter. What is the **MOST** important item to define first?

(A) The brand of meeting software

(B) Its purpose, authority, membership, and reporting line to the board

(C) The list of approved vendors

(D) The committee's lunch schedule

Q1: Explanation

Correct Answer: B

- A charter establishes legitimacy and scope.
- Authority determines what decisions it can make.
- A clear reporting line supports oversight.

Key Takeaway

Define authority before activity.

Q2: Enterprise Risk Integration

Question

IT risk is managed separately from enterprise risk, producing conflicting ratings. What is the **BEST** improvement?

(A) Keep them separate to preserve independence

(B) Let IT use its own scale permanently

(C) Remove IT risk from reports

(D) Integrate IT risk into the enterprise risk framework using common criteria and reporting

Q2: Explanation

Correct Answer: D

- Common criteria allow comparison across risk types.
- IT risk affects business objectives.
- Integrated views support better decisions.

Key Takeaway

IT risk is business risk.

Q3: Risk Taxonomy

Question

Departments describe the same risk using different terms, causing confusion in reports. What should be implemented?

(A) A common risk taxonomy and glossary approved by governance

(B) More frequent meetings with no changes

(C) A larger spreadsheet

(D) A rule that only IT may name risks

Q3: Explanation

Correct Answer: A

- Shared language reduces misinterpretation.
- Governance approval gives it authority.
- Consistency improves aggregation.

Key Takeaway

Speak one risk language.

Q4: Vendor Gifts

Question

A vendor under evaluation offers the risk practitioner expensive concert tickets. What is the **BEST** response?

(A) Accept because it is only a gift

(B) Accept and rate the vendor higher

(C) Decline and disclose the offer in line with the organization's code of conduct

(D) Accept and tell nobody

Q4: Explanation

Correct Answer: C

- Gifts can influence objectivity.
- Policies usually require disclosure.
- Independence protects the assessment.

Key Takeaway

Protect objectivity; decline and disclose.

Q5: Incentives and Risk Behavior

Question

Sales bonuses reward revenue only, and staff bypass security approvals to close deals. What is the **ROOT** governance issue?

(A) Salespeople are inherently careless

(B) Incentives are not aligned with the organization's risk appetite and policies

(C) Security approvals are too short

(D) Software is too old

Q5: Explanation

Correct Answer: B

- People respond to what is rewarded.
- Governance should align incentives with risk behavior.
- Fixing symptoms without incentives will not hold.

Key Takeaway

Culture follows incentives.

Q6: IT Steering Committee

Question

Which role is **MOST** appropriate for an IT steering committee?

(A) Configure servers

(B) Write all code

(C) Prioritize IT investments and monitor alignment with business strategy

(D) Handle help desk tickets

Q6: Explanation

Correct Answer: C

- Steering committees provide direction and oversight.
- Business and IT leaders both participate.
- Operational tasks stay with management.

Key Takeaway

Steering sets direction, not settings.

Q7: Delegation of Authority

Question

A project manager approves a risk acceptance far above their delegated limit. What is the **BEST** action?

(A) Accept it because it is already signed

(B) Treat the approval as invalid and route it to the appropriate authority

(C) Hide the document

(D) Increase the limit retroactively without review

Q7: Explanation

Correct Answer: B

- Authority limits control who may accept risk.
- Invalid approvals leave risk unmanaged.
- Retroactive changes undermine governance.

Key Takeaway

Approval is valid only at the right level.

Q8: Policy Conflicts

Question

Two policies give conflicting retention requirements for the same data. What should the risk practitioner do?

(A) Follow whichever is easier

(B) Ignore both policies

(C) Raise the conflict with policy owners and legal so governance can resolve and harmonize it

(D) Delete the data

Q8: Explanation

Correct Answer: C

- Conflicts create compliance risk.
- Policy owners must reconcile them.
- Legal input confirms obligations.

Key Takeaway

Resolve policy conflicts at the source.

Q9: Regulatory Change Management

Question

New regulations are published several times a year. Which governance practice is **MOST** effective?

(A) Wait for audits to mention changes

(B) Assign changes to whoever is available

(C) A defined process to monitor, interpret, and assign actions for regulatory changes

(D) Review regulations every five years

Q9: Explanation

Correct Answer: C

- Monitoring prevents surprise non-compliance.
- Assigned owners ensure action.
- Process makes response repeatable.

Key Takeaway

Make regulatory change a process, not a surprise.

Q10: Data Governance Council

Question

What is the **PRIMARY** benefit of a data governance council?

(A) Faster hardware purchases

(B) Consistent ownership, classification, quality, and usage decisions across the enterprise

(C) Lower electricity costs

(D) Fewer staff meetings

Q10: Explanation

Correct Answer: B

- Data decisions cross business units.
- A council clarifies owners and rules.
- Quality and privacy risks fall.

Key Takeaway

Shared data needs shared rules.

Q11: Risk-Based Audit Plan

Question

How should internal audit **BEST** determine its annual audit plan?

(A) Audit the same areas each year

(B) Audit by alphabetical department

(C) Let each department choose

(D) Using a risk-based approach that reflects the organization's key risks and objectives

Q11: Explanation

Correct Answer: D

- Risk-based planning focuses on what matters.
- Plans should respond to changing risk.
- Coverage should be explainable to the board.

Key Takeaway

Audit where the risk is.

Q12: Merger and Appetite

Question

After acquiring a company with a very different risk culture, what should the board do regarding risk appetite?

(A) Leave it unchanged forever

(B) Adopt the smaller company's appetite without discussion

(C) Review and, where needed, update the enterprise appetite and communicate it to the combined organization

(D) Eliminate appetite statements

Q12: Explanation

Correct Answer: C

- Business change can alter risk exposure.
- Appetite should reflect current strategy.
- Communication drives consistent behavior.

Key Takeaway

Re-examine appetite after major change.

Q13: Project Risk Roles

Question

A large project has no defined risk roles. What is the **BEST** action?

(A) Wait until problems occur

(B) Make the vendor responsible

(C) Define risk roles and responsibilities, including who owns and reviews project risks

(D) Assign all risks to the project sponsor's assistant

Q13: Explanation

Correct Answer: C

- Clear roles ensure risks are managed.
- Owners need authority.
- Early definition prevents gaps.

Key Takeaway

Define who does what before the project starts.

Q14: Shadow IT Governance

Question

Business units increasingly buy cloud tools without IT involvement. What is the **BEST** governance response?

(A) Provide an efficient, risk-based intake process and clear policy so teams can adopt tools safely

(B) Ban all cloud tools

(C) Ignore it

(D) Punish all teams

Q14: Explanation

Correct Answer: A

- Friction drives shadow IT.
- A simple process improves visibility.
- Risk-based review keeps oversight proportionate.

Key Takeaway

Make the secure path the easy path.

Q15: Risk Awareness Training

Question

Which measure **BEST** indicates that risk awareness training is working?

(A) The number of slides in the course

(B) Improved behavior, such as lower phishing click rates and more timely issue reporting

(C) Hours of video watched

(D) The number of emails sent

Q15: Explanation

Correct Answer: B

- Outcomes show real change.
- Completion rates alone are weak.
- Behavior metrics guide improvement.

Key Takeaway

Measure behavior, not attendance.

Q16: Board Reporting Cadence

Question

The board receives risk reports only once a year. What is the **MOST** significant concern?

(A) Reports are too short

(B) The board has too little coffee

(C) Emerging risks and breaches of appetite may not be reported in time for oversight

(D) Reports are in color

Q16: Explanation

Correct Answer: C

- Oversight needs timely information.
- Material changes require escalation outside the cycle.
- Frequency should reflect volatility.

Key Takeaway

Report at the speed of risk.

Q17: Outsourcing Governance

Question

The organization outsources a critical process. Which governance element is **MOST** important?

(A) Only the lowest price

(B) Trusting verbal promises

(C) Removing internal oversight

(D) Clear service levels, defined oversight responsibilities, and exit and continuity provisions

Q17: Explanation

Correct Answer: D

- Oversight must be defined internally.
- Exit provisions reduce lock-in.
- Service levels make performance measurable.

Key Takeaway

Outsource the work, keep the oversight.

Q18: Ethical AI Use

Question

The company deploys AI for hiring screening. Which governance step is **MOST** important?

(A) Let the algorithm decide alone

(B) Publish no information

(C) Establish accountability, bias testing, transparency, and human review of decisions

(D) Use only the cheapest model

Q18: Explanation

Correct Answer: C

- AI can embed bias.
- Humans remain accountable.
- Transparency supports trust.

Key Takeaway

Automated decisions need human accountability.

Q19: Policy Exception Trends

Question

Exception requests for one policy have tripled in a year. What should the risk practitioner conclude and do?

(A) The policy may be impractical or misaligned, so review it with its owner and the business

(B) Approve all exceptions automatically

(C) Stop accepting exception requests

(D) Conclude users are malicious

Q19: Explanation

Correct Answer: A

- Patterns of exceptions signal design problems.
- Policy owners should review applicability.
- Governance should adjust or enforce deliberately.

Key Takeaway

Many exceptions mean the policy needs attention.

Q20: Business Ownership of IT Risk

Question

IT is asked to accept risks arising from a business-owned application. What is the **BEST** response?

(A) Clarify that the business owner is accountable for the risk, with IT providing advice and support

(B) Accept it because IT runs the servers

(C) Refuse to engage

(D) Assign it to the vendor

Q20: Explanation

Correct Answer: A

- Risk ownership follows business process accountability.
- IT supports with expertise.
- Clear ownership improves decisions.

Key Takeaway

Business processes carry business risk.

Q21: Performance of Risk Owners

Question

Risk owners rarely update their risks. What is the **BEST** way to improve this?

(A) Update the risks for them forever

(B) Delete their risks

(C) Define expectations, provide support and reminders, and include risk responsibilities in performance objectives

(D) Hide the issue

Q21: Explanation

Correct Answer: C

- Accountability needs expectations.
- Support makes it easier.
- Alignment with objectives gives it weight.

Key Takeaway

Make risk ownership part of the job.

Q22: Gaining Executive Support

Question

Executives view risk management as a compliance burden. What is the **BEST** approach?

(A) Add more forms

(B) Threaten with audits

(C) Reduce reporting entirely

(D) Demonstrate how risk information improves decisions and helps achieve strategic goals

Q22: Explanation

Correct Answer: D

- Value in business terms earns support.
- Link risk to objectives.
- Share examples of decisions improved.

Key Takeaway

Sell risk management as decision support.

Q23: Open Communication of Risk

Question

A risk practitioner finds that important risks are not shared across departments. What should be improved?

(A) Establish regular cross-functional risk communication and shared reporting channels

(B) Keep all risks private

(C) Share only good news

(D) Limit sharing to IT

Q23: Explanation

Correct Answer: A

- Interdependencies need shared awareness.
- Channels should be defined.
- Transparency builds trust.

Key Takeaway

Risks do not respect department boundaries.

Q24: Risk Culture Measurement

Question

How can the organization **BEST** assess its risk culture?

(A) Through surveys, incident reporting patterns, and observed behavior of leaders and staff

(B) By reading the policy manual

(C) By counting servers

(D) By asking only the board

Q24: Explanation

Correct Answer: A

- Multiple indicators reveal culture.
- Reporting patterns show trust.
- Leaders' behavior is influential.

Key Takeaway

Culture is observed in behavior.

Q25: Strategy Pivot Risk

Question

Leadership announces a pivot to a new business model. What should the risk practitioner do?

(A) Continue using last year's assessment unchanged

(B) Oppose the pivot

(C) Wait for incidents

(D) Assess how the new strategy changes the risk profile and update appetite, scenarios, and reporting

Q25: Explanation

Correct Answer: D

- Strategy changes risk exposure.
- Early assessment informs decisions.
- Reporting should reflect new risks.

Key Takeaway

New strategy means a new risk profile.

Q26: Independence of Risk Reporting

Question

A business head asks the risk function to soften a risk report before it goes to the board. What is the **BEST** response?

(A) Soften the report as requested

(B) Explain that the report must be accurate and offer to add the business's response and context

(C) Remove the risk from the report

(D) Send a different version to the business only

Q26: Explanation

Correct Answer: B

- Boards need unbiased information.
- Business context can be added transparently.
- Altering facts damages credibility.

Key Takeaway

Accurate reports, with context added openly.

Q27: Scenario Selection

Question

The team must choose risk scenarios for an assessment. Which approach is **BEST**?

(A) Choose only scenarios that have already happened

(B) Choose the most dramatic scenarios

(C) Select plausible scenarios tied to key business processes, using input from owners and threat information

(D) Choose scenarios at random

Q27: Explanation

Correct Answer: C

- Scenarios should be relevant and plausible.
- Owners understand business impact.
- Threat data improves realism.

Key Takeaway

Relevant scenarios beat dramatic ones.

Q28: Estimating With Uncertainty

Question

Data on loss frequency is limited. What is the **BEST** way to estimate?

(A) Use a single exact guess

(B) Use calibrated ranges from experts and available data, and document assumptions

(C) Refuse to estimate

(D) Use the highest number possible

Q28: Explanation

Correct Answer: B

- Ranges express uncertainty honestly.
- Calibration reduces bias.
- Assumptions can be reviewed and improved.

Key Takeaway

Estimate with ranges and documented assumptions.

Q29: Optimism Bias

Question

Assessors consistently rate their own area's risks as low. Which action **BEST** addresses this bias?

(A) Apply independent challenge and calibration from the second line

(B) Trust self-ratings completely

(C) Eliminate self-assessments

(D) Increase all ratings by one level

Q29: Explanation

Correct Answer: A

- Independent challenge improves objectivity.
- Calibration aligns standards.
- Self-assessment is still useful with review.

Key Takeaway

Challenge self-ratings independently.

Q30: Interdependent Risks

Question

Two risks are rated medium separately, but both depend on the same data center. What should the assessment consider?

(A) The common dependency, since a single failure could cause combined and higher impact

(B) Nothing; rate each separately

(C) Remove both risks

(D) Lower both ratings

Q30: Explanation

Correct Answer: A

- Dependencies create compounding effects.
- Aggregation reveals concentration.
- Shared causes call for shared responses.

Key Takeaway

Look for common causes.

Q31: Sensitivity Analysis

Question

What is the purpose of sensitivity analysis in risk assessment?

(A) To hide uncertainty

(B) To see how changes in assumptions affect results and identify the most influential inputs

(C) To replace expert judgment

(D) To increase the number of risks

Q31: Explanation

Correct Answer: B

- It tests the robustness of estimates.
- Influential inputs deserve better data.
- It improves confidence in decisions.

Key Takeaway

Test how much the answer depends on the assumptions.

Q32: Monte Carlo Concept

Question

A quantitative model runs thousands of simulations using ranges for frequency and loss. What does this produce?

(A) A distribution of possible outcomes showing the range and likelihood of losses

(B) One guaranteed loss figure

(C) A list of vulnerabilities

(D) A compliance certificate

Q32: Explanation

Correct Answer: A

- Simulation reflects uncertainty.
- Distributions support appetite comparisons.
- Quality depends on input quality.

Key Takeaway

Simulation shows a range, not a promise.

Q33: Data Quality for Assessment

Question

The assessment relies on an asset inventory known to be 40 percent out of date. What is the **BEST** action?

(A) Disclose the limitation and improve inventory accuracy, prioritizing critical assets

(B) Proceed and present results as precise

(C) Cancel the assessment permanently

(D) Use only the oldest data

Q33: Explanation

Correct Answer: A

- Results depend on inputs.
- Transparency about limits preserves credibility.
- Prioritize critical assets first.

Key Takeaway

Disclose data limits; do not hide them.

Q34: Control Gap Analysis

Question

What is the **PRIMARY** output of a control gap analysis?

(A) A list of employee names

(B) Identification of differences between required or desired controls and those currently in place

(C) A purchase order

(D) A new policy only

Q34: Explanation

Correct Answer: B

- Gaps show where risk may be unmitigated.
- They feed response planning.
- Required controls come from risk and obligations.

Key Takeaway

A gap analysis shows what is missing.

Q35: Red Team vs Pen Test

Question

How does a red team exercise differ from a standard penetration test?

(A) It is the same thing

(B) It simulates a realistic adversary with broader objectives and tests detection and response, not only vulnerabilities

(C) It uses only automated scans

(D) It avoids any realistic tactics

Q35: Explanation

Correct Answer: B

- Red teams emulate real attackers.
- They test people, processes, and technology.
- Results inform detection improvements.

Key Takeaway

Red teams test the defenders as well as the systems.

Q36: Assessment Scope

Question

A pen test is requested. What should be agreed **FIRST**?

(A) Scope, rules of engagement, and authorization, including safe handling of data

(B) Which tools look best

(C) The report's cover design

(D) Nothing; just begin

Q36: Explanation

Correct Answer: A

- Unauthorized testing creates legal risk.
- Rules protect production systems.
- Scope ensures relevance.

Key Takeaway

Test with permission and boundaries.

Q37: Legacy System Assessment

Question

A legacy system cannot be scanned safely. How should risk be assessed?

(A) Treat the system as risk-free

(B) Scan it anyway without planning

(C) Use alternative methods such as architecture review, configuration review, and compensating control analysis

(D) Ignore the system

Q37: Explanation

Correct Answer: C

- Safe alternatives still provide insight.
- Compensating controls matter.
- Document limitations.

Key Takeaway

If you cannot scan it, you still must assess it.

Q38: Assessment Frequency

Question

How often should risk assessments of critical systems be performed?

(A) At planned intervals based on risk and whenever significant changes occur

(B) Once at system creation only

(C) Only after incidents

(D) Every ten years

Q38: Explanation

Correct Answer: A

- Risk changes over time.
- Higher risk warrants more frequent review.
- Triggers ensure timeliness.

Key Takeaway

Assess regularly and on change.

Q39: Residual Risk Validation

Question

The assessed residual risk assumes a control works perfectly, but testing shows it works about half the time. What should happen?

(A) Keep the original rating

(B) Remove the control from the assessment

(C) Re-rate residual risk based on observed control effectiveness

(D) Cancel testing

Q39: Explanation

Correct Answer: C

- Residual risk should reflect real performance.
- Testing evidence overrides assumptions.
- Update the register and inform owners.

Key Takeaway

Residual risk follows actual control performance.

Q40: Equal Scores

Question

Several risks have the same score. How should they be prioritized?

(A) Pick alphabetically

(B) Ignore all of them

(C) Use the order received

(D) Consider additional factors such as velocity, proximity, dependency, and strategic importance

Q40: Explanation

Correct Answer: D

- Scores are only part of the picture.
- Timing and criticality matter.
- Judgment should be explained.

Key Takeaway

Tie-breakers need business logic.

Q41: New Vendor Assessment Depth

Question

How deep should a third-party risk assessment be?

(A) Identical for every vendor

(B) As minimal as possible

(C) Based on vendor size only

(D) Proportional to the vendor's criticality and the sensitivity of data and access involved

Q41: Explanation

Correct Answer: D

- Risk-based depth saves effort.
- High-criticality vendors need more evidence.
- Reassess as relationships change.

Key Takeaway

Depth follows criticality.

Q42: IoT Assessment

Question

A factory adds many connected sensors. Which risk consideration is **MOST** important in the assessment?

(A) Device inventory, firmware update ability, authentication, and network segmentation

(B) Sensor color

(C) Number of cables

(D) Brand logos

Q42: Explanation

Correct Answer: A

- IoT often has weak default security.
- Update capability determines long-term risk.
- Segmentation limits impact.

Key Takeaway

IoT assessment starts with inventory and updateability.

Q43: Expert Elicitation

Question

Experts disagree widely on a risk's likelihood. What is the **BEST** approach?

(A) Use the most senior person's number

(B) Discard the outliers always

(C) Explore the reasoning behind each view and use structured methods to combine estimates

(D) Use the lowest estimate

Q43: Explanation

Correct Answer: C

- Disagreement reveals assumptions.
- Structured methods reduce bias.
- Document the rationale.

Key Takeaway

Surface the reasoning behind the numbers.

Q44: Business Dependency Mapping

Question

Why map dependencies between business processes and IT services?

(A) To reduce printer use

(B) To impress auditors

(C) To understand how an IT failure would affect business processes and to prioritize protection

(D) To avoid assessments

Q44: Explanation

Correct Answer: C

- Mapping links IT risk to business impact.
- It informs BIA and recovery priorities.
- It reveals hidden single points of failure.

Key Takeaway

Map the dependencies to understand real impact.

Q45: Assessing Change

Question

A major system upgrade is planned. When should the risk assessment of the change be performed?

(A) After go-live

(B) During planning, before approval and implementation

(C) One year later

(D) Only if the upgrade fails

Q45: Explanation

Correct Answer: B

- Early assessment informs go or no-go decisions.
- Mitigations can be built in.
- Late assessment is costlier.

Key Takeaway

Assess change before approving it.

Q46: Communicating Uncertainty

Question

How should the risk practitioner present estimates that carry considerable uncertainty?

(A) Show a single precise number

(B) Hide all uncertainty

(C) Avoid presenting any estimate

(D) Present ranges and confidence levels with clear assumptions, not false precision

Q46: Explanation

Correct Answer: D

- Honest uncertainty builds trust.
- Decision makers can weigh ranges.
- False precision misleads.

Key Takeaway

Do not claim more accuracy than you have.

Q47: Response Selection Pressure

Question

Executives pressure the practitioner to choose the cheapest response for a high risk. What is the **BEST** approach?

(A) Choose the cheapest regardless

(B) Choose the costliest regardless

(C) Avoid presenting options

(D) Present response options with costs and residual risk so the owner can decide within appetite

Q47: Explanation

Correct Answer: D

- Owners decide with full information.
- Residual risk shows what remains.
- Appetite is the benchmark.

Key Takeaway

Options and residual risk enable decisions.

Q48: Funding Action Plans

Question

Approved risk response plans lack funding. What should the practitioner do?

(A) Escalate the funding gap and the resulting residual risk to decision makers

(B) Close the plans

(C) Reduce the risk rating

(D) Wait silently

Q48: Explanation

Correct Answer: A

- Unfunded plans leave risk unchanged.
- Decision makers must know the exposure.
- They may adjust funding or accept the risk.

Key Takeaway

An unfunded plan is not a response.

Q49: Designing KRIs

Question

Which criterion is **MOST** important when designing a KRI?

(A) It is complicated to calculate

(B) It is available only annually

(C) It is linked to a specific risk and supports a decision when it changes

(D) It reflects past events only

Q49: Explanation

Correct Answer: C

- Relevance to a risk is essential.
- KRIs should trigger action.
- Timely and measurable data is needed.

Key Takeaway

A KRI must lead to a decision.

Q50: KCI Meaning

Question

A key control indicator shows that only 55 percent of required system backups succeeded last week. What does this **MOST** suggest?

(A) Data loss risk has decreased

(B) Backups are unnecessary

(C) The indicator is irrelevant

(D) The backup control is not operating effectively, increasing data loss risk

Q50: Explanation

Correct Answer: D

- KCIs measure control performance.
- Low success means weaker protection.
- Investigate and remediate.

Key Takeaway

A failing KCI signals a failing control.

Q51: Dashboard Design

Question

An executive dashboard shows many technical metrics without context. How should it be improved?

(A) Add more technical metrics

(B) Remove all trends

(C) Make it harder to read

(D) Focus on key risks versus appetite, trends, and decisions needed

Q51: Explanation

Correct Answer: D

- Executives need decision-ready information.
- Trends show direction.
- Context links metrics to appetite.

Key Takeaway

Dashboards should drive decisions.

Q52: Verifying Closure

Question

A team marks an audit finding as closed after implementing a fix. What should happen before the finding is truly closed?

(A) Independent verification that the fix is effective

(B) Nothing; the team reports closure

(C) A new policy only

(D) A vendor email

Q52: Explanation

Correct Answer: A

- Self-reported closure may be incomplete.
- Verification provides assurance.
- Update residual risk afterward.

Key Takeaway

Closed means verified.

Q53: Exception Renewal

Question

A policy exception has been renewed five times without progress toward compliance. What should the practitioner do?

(A) Renew it indefinitely

(B) Quietly remove it

(C) Escalate and require a realistic remediation plan or a formal risk acceptance at the right level

(D) Hide the history

Q53: Explanation

Correct Answer: C

- Repeated renewals signal unmanaged risk.
- Plans and dates drive progress.
- Acceptance needs proper authority.

Key Takeaway

Exceptions should end, not renew forever.

Q54: Sample Size

Question

A control operates thousands of times per month. How should testing be approached?

(A) Test one instance only

(B) Use a statistically or risk-based appropriate sample covering the period

(C) Test only the first day

(D) Test nothing

Q54: Explanation

Correct Answer: B

- Samples must represent the population.
- Higher risk warrants larger samples.
- Document the approach.

Key Takeaway

Sample enough to conclude.

Q55: Continuous Controls Monitoring

Question

What is a key benefit of continuous controls monitoring?

(A) It removes all risk

(B) Faster detection of control failures through automated, ongoing testing

(C) It eliminates control owners

(D) It replaces management oversight

Q55: Explanation

Correct Answer: B

- Automation tests frequently.
- Early detection shortens exposure.
- Owners still respond to alerts.

Key Takeaway

Continuous tests catch failures sooner.

Q56: Escalation Criteria

Question

The practitioner is unsure when to escalate risk issues. What should exist?

(A) Personal discretion only

(B) No escalation at all

(C) Escalation only after incidents

(D) Defined escalation criteria and thresholds approved by governance

Q56: Explanation

Correct Answer: D

- Clear criteria ensure consistency.
- Thresholds link to appetite.
- Approval gives authority.

Key Takeaway

Define when to escalate.

Q57: Stale Register

Question

Half the risk register entries have not been reviewed in over a year. What is the **BEST** action?

(A) Delete half the entries

(B) Run a review cycle with owners, retire obsolete entries, and set recurring review dates

(C) Ignore it

(D) Rate all as low

Q57: Explanation

Correct Answer: B

- Stale data misleads decisions.
- Owners confirm current status.
- Recurring dates maintain quality.

Key Takeaway

A register is only as good as its freshness.

Q58: Measuring Response Effectiveness

Question

How should the effectiveness of a risk response be measured?

(A) By whether the project finished on time

(B) By how much money was spent

(C) By whether the actual risk exposure moved within appetite, as shown by indicators and testing

(D) By the number of meetings

Q58: Explanation

Correct Answer: C

- The goal is reduced exposure.
- Indicators and tests provide evidence.
- Activity is not the same as outcome.

Key Takeaway

Effective response means reduced exposure.

Q59: Residual Risk Sign-Off

Question

After mitigation, residual risk remains slightly above appetite. Who should decide whether to accept it?

(A) The risk practitioner alone

(B) The vendor

(C) The internal auditor

(D) The risk owner with senior management or governance approval as required

Q59: Explanation

Correct Answer: D

- Owners and management hold authority.
- Above-appetite risk needs higher approval.
- Decisions must be documented.

Key Takeaway

Above-appetite acceptance needs senior approval.

Q60: Vendor Remediation Tracking

Question

A vendor promised to fix a significant weakness by the end of last quarter but has not. What should the practitioner do?

(A) Wait without action

(B) Remove the finding

(C) Pay a bonus

(D) Escalate under the contract, reassess the risk, and consider compensating controls or alternatives

Q60: Explanation

Correct Answer: D

- Contracts provide escalation levers.
- Risk continues until fixed.
- Contingencies reduce exposure.

Key Takeaway

Hold vendors to their remediation promises.

Q61: Change and Risk

Question

Emergency changes bypass normal review frequently. What is the **BEST** control improvement?

(A) Define an emergency change process with after-the-fact review and metrics on emergency use

(B) Ban all emergency changes

(C) Allow all changes without records

(D) Ignore the pattern

Q61: Explanation

Correct Answer: A

- Emergencies happen but need control.
- Post review ensures accountability.
- Metrics reveal abuse.

Key Takeaway

Control the exception path too.

Q62: DR Test Reporting

Question

A DR test met only half of its recovery time objectives. How should this be reported?

(A) Report the gaps, the business impact, and a remediation plan with owners and dates

(B) Report success anyway

(C) Hide results

(D) Blame the test team

Q62: Explanation

Correct Answer: A

- Honest reporting enables improvement.
- Business impact gives context.
- Plans drive closure.

Key Takeaway

Report failures as clearly as successes.

Q63: Incident Metrics

Question

Which incident metric is **MOST** useful for management oversight?

(A) Number of emails about incidents

(B) Trends in severity, time to detect, and time to contain or recover

(C) Names of those involved only

(D) The color of the incident form

Q63: Explanation

Correct Answer: B

- Trends show whether capability is improving.
- Time metrics show responsiveness.
- Severity reflects business impact.

Key Takeaway

Trend the outcomes.

Q64: Insurance Exclusions

Question

Before relying on cyber insurance as a response, what should be reviewed?

(A) The insurer's logo

(B) Only the premium

(C) Nothing

(D) Coverage limits, exclusions, and conditions, such as required controls

Q64: Explanation

Correct Answer: D

- Policies may exclude events or require controls.
- Limits may be lower than potential loss.
- Misunderstanding coverage creates false assurance.

Key Takeaway

Read the exclusions before you rely on the policy.

Q65: Validating Compensating Controls

Question

A compensating control is used in place of a standard control. What should be done?

(A) Assume it is equivalent

(B) Assess that it addresses the same risk to an equivalent degree and document it

(C) Remove the standard

(D) Keep it secret

Q65: Explanation

Correct Answer: B

- Compensating controls must be effective.
- Documentation supports review.
- Test periodically.

Key Takeaway

Compensate only with equivalence.

Q66: System Decommissioning

Question

A system is being retired. Which risk activity is **MOST** important?

(A) Turn it off and forget it

(B) Leave accounts active

(C) Keep it online unmonitored

(D) Ensure data is migrated or securely destroyed, access removed, and records updated

Q66: Explanation

Correct Answer: D

- Retired systems can leak data.
- Orphan accounts are risks.
- Inventory must reflect reality.

Key Takeaway

Decommission thoroughly.

Q67: Patch Exceptions

Question

A critical patch cannot be applied for three months due to business constraints. What is the **BEST** approach?

(A) Ignore the patch

(B) Remove monitoring

(C) Delay reporting

(D) Record a time-bound exception with compensating controls and owner approval

Q67: Explanation

Correct Answer: D

- Exceptions need compensating controls.
- Time limits keep pressure on closure.
- Owner approval maintains accountability.

Key Takeaway

Delay with controls, not silence.

Q68: Risk Trending

Question

Why is trend analysis useful in risk reporting?

(A) It hides outliers

(B) It shows whether exposure is improving or worsening and supports proactive decisions

(C) It replaces appetite

(D) It is only for auditors

Q68: Explanation

Correct Answer: B

- Direction matters as much as level.
- Trends can predict threshold breaches.
- They support timely action.

Key Takeaway

Report the direction as well as the position.

Q69: Regulator Reporting Accuracy

Question

Data for a regulatory report is compiled manually from several sources. What is the **BEST** improvement?

(A) Submit unreviewed

(B) Rely on one person's memory

(C) Define controls over data accuracy, reconciliation, and review before submission

(D) Skip reconciliation

Q69: Explanation

Correct Answer: C

- Regulatory errors carry penalties.
- Reconciliation verifies completeness.
- Review adds assurance.

Key Takeaway

Control the data behind regulatory reports.

Q70: Communicating to Non-Technical Owners

Question

How should a risk practitioner explain a technical vulnerability to a business owner?

(A) Translate it into potential business impact, likelihood, and available response options

(B) Use detailed exploit code

(C) Use only technical jargon

(D) Avoid explaining

Q70: Explanation

Correct Answer: A

- Owners decide in business terms.
- Options enable choice.
- Clear language builds trust.

Key Takeaway

Translate technical risk into business impact.

Q71: Control Optimization

Question

Several overlapping controls address the same low risk at high cost. What should be done?

(A) Evaluate rationalizing redundant controls while keeping risk within appetite

(B) Add more controls

(C) Remove all controls

(D) Ignore costs

Q71: Explanation

Correct Answer: A

- Efficiency matters in risk programs.
- Redundancy is valuable only where justified.
- Appetite is the constraint.

Key Takeaway

Optimize controls, do not just accumulate them.

Q72: Reliance on Others' Assurance

Question

May the risk practitioner rely on an internal audit report as evidence about a control?

(A) Never use others' work

(B) Yes, after considering the scope, timing, independence, and quality of the audit work

(C) Use any report blindly

(D) Use only vendor claims

Q72: Explanation

Correct Answer: B

- Reliance requires judgment.
- Scope must match the control.
- Timing affects relevance.

Key Takeaway

Rely on others' work only after evaluating it.

Q73: KRI Data Reliability

Question

A KRI relies on data that is manually entered and inconsistent. What is the **BEST** action?

(A) Ignore the KRI

(B) Improve data collection, automate where possible, and validate quality

(C) Use it as is

(D) Hide the data source

Q73: Explanation

Correct Answer: B

- Unreliable data misleads.
- Automation increases consistency.
- Validation builds confidence.

Key Takeaway

Fix the data before trusting the indicator.

Q74: Risk Acceptance Review

Question

A risk was accepted two years ago. When should the acceptance be reviewed?

(A) Periodically and whenever conditions change significantly

(B) Never

(C) Only if someone complains

(D) After the owner leaves only

Q74: Explanation

Correct Answer: A

- Acceptance is based on conditions that may change.
- Reviews confirm continued validity.
- Owner changes also trigger reviews.

Key Takeaway

Acceptance is not forever.

Q75: Third-Party Reporting

Question

How should third-party risk be reported to management?

(A) List every vendor equally

(B) Highlight critical vendors, key findings, concentration, and remediation status against appetite

(C) Report only vendor names

(D) Skip reporting

Q75: Explanation

Correct Answer: B

- Focus on what matters.
- Concentration is a key concern.
- Status shows progress.

Key Takeaway

Report the vendors that matter.

Q76: Final Risk Position

Question

Management asks for the overall risk posture after a series of responses. What should the practitioner provide?

(A) Only the list of completed tasks

(B) The number of hours worked

(C) Updated residual risk positions against appetite, with trends and open decisions

(D) A guarantee of no incidents

Q76: Explanation

Correct Answer: C

- Posture means exposure relative to appetite.
- Trends and open items guide decisions.
- No one can guarantee zero incidents.

Key Takeaway

Report posture, not just progress.

Q77: Closing the Loop With Owners

Question

After a risk report is issued, the risk owners do not respond. What should the practitioner do?

(A) Assume silence means acceptance

(B) Close the risks

(C) Stop reporting

(D) Follow up, confirm they understood the risks and options, and escalate if no decision is made

Q77: Explanation

Correct Answer: D

- Silence is not acceptance.
- Follow-up ensures understanding.
- Escalation secures a decision.

Key Takeaway

Silence is not a decision.

Q78: Risk Appetite Breach Response

Question

A KRI shows that a risk has breached its tolerance threshold for the second month. What is the **BEST** action?

(A) Escalate to the risk owner and governance per the defined process and agree on corrective actions

(B) Wait one more month

(C) Change the threshold to remove the breach

(D) Delete the KRI

Q78: Explanation

Correct Answer: A

- Persistent breaches need action.
- Thresholds reflect approved tolerance.
- Governance decides on exceptions.

Key Takeaway

Breaches trigger escalation, not threshold changes.

Q79: Email Authentication

Question

Attackers keep sending emails that spoof the company's domain. Which control set **BEST** reduces this?

(A) SPF, DKIM, and DMARC email authentication with enforcement

(B) Longer email subject lines

(C) Larger mailboxes

(D) More email signatures

Q79: Explanation

Correct Answer: A

- These standards verify sender legitimacy.
- Enforcement tells receivers to reject spoofed mail.
- Monitoring reports reveal abuse.

Key Takeaway

Authenticate your domain's email.

Q80: Endpoint Detection

Question

Traditional antivirus misses several advanced attacks. Which capability **BEST** improves detection on endpoints?

(A) A bigger monitor

(B) Password sticky notes

(C) Endpoint detection and response with behavioral monitoring

(D) Disabling updates

Q80: Explanation

Correct Answer: C

- Behavior-based tools detect unknown threats.
- EDR supports investigation and containment.
- It complements, not replaces, other controls.

Key Takeaway

Detect behavior, not just signatures.

Q81: Data Loss Prevention

Question

What is the main purpose of data loss prevention tools?

(A) To speed up networks

(B) To compress files

(C) To detect and block unauthorized transfer of sensitive data based on policy

(D) To replace backups

Q81: Explanation

Correct Answer: C

- DLP enforces data handling rules.
- Classification improves accuracy.
- Tuning reduces false positives.

Key Takeaway

DLP guards the exits.

Q82: Encryption at Rest

Question

A laptop containing sensitive data is lost. Which control **BEST** limits the impact?

(A) A screen saver

(B) A louder alarm

(C) A longer warranty

(D) Full-disk encryption with strong key protection

Q82: Explanation

Correct Answer: D

- Encrypted data is unreadable without keys.
- Key protection is critical.
- Remote wipe adds further protection.

Key Takeaway

Lost device, protected data.

Q83: Transport Security

Question

Sensitive data is sent between systems over an untrusted network. Which control **BEST** protects it in transit?

(A) Plain text transfer

(B) Obscure port numbers

(C) Compression only

(D) Strong transport encryption such as current TLS versions

Q83: Explanation

Correct Answer: D

- Encryption prevents eavesdropping.
- Current protocol versions avoid known weaknesses.
- Certificate validation prevents impersonation.

Key Takeaway

Encrypt in transit with current protocols.

Q84: Single Sign-On

Question

What is a security benefit of single sign-on with strong authentication?

(A) No need for any authentication

(B) Elimination of all risk

(C) Fewer passwords to manage and centralized control of access and logging

(D) Shared passwords among staff

Q84: Explanation

Correct Answer: C

- Central policies are easier to enforce.
- Users avoid password reuse.
- The identity provider becomes critical and must be protected.

Key Takeaway

SSO simplifies control but concentrates risk.

Q85: Role-Based Access

Question

Access permissions are assigned individually and have become inconsistent. What is the **BEST** improvement?

(A) Give everyone admin rights

(B) Let managers use any approach

(C) Remove all reviews

(D) Implement role-based access control aligned to job functions and review it periodically

Q85: Explanation

Correct Answer: D

- Roles standardize permissions.
- Reviews catch drift.
- Least privilege is easier to maintain.

Key Takeaway

Roles make least privilege manageable.

Q86: Database Protection

Question

Which combination **BEST** protects a database containing sensitive records?

(A) A single shared account

(B) Public internet exposure

(C) Access controls, encryption, activity monitoring, and secure configuration

(D) No logging

Q86: Explanation

Correct Answer: C

- Layered controls reduce exposure.
- Monitoring detects misuse.
- Configuration prevents known weaknesses.

Key Takeaway

Protect data where it lives.

Q87: Backup Strategy

Question

Which approach is the **BEST** backup practice for resilience against ransomware?

(A) Multiple copies on different media with at least one offline or immutable copy, regularly tested

(B) One copy on the same server

(C) Backups never tested

(D) Backups on a mapped network drive only

Q87: Explanation

Correct Answer: A

- Diversity reduces common failure.
- Offline copies resist encryption attacks.
- Testing proves recoverability.

Key Takeaway

Multiple copies, one offline, all tested.

Q88: Web Application Firewall

Question

What does a web application firewall primarily help protect against?

(A) Disk failures

(B) Printer jams

(C) Power outages

(D) Common web attacks such as injection and cross-site scripting targeting web applications

Q88: Explanation

Correct Answer: D

- A WAF filters malicious application traffic.
- It complements secure coding.
- Rules need tuning.

Key Takeaway

WAF protects web apps, not hardware.

Q89: Authenticated Scanning

Question

Why is authenticated vulnerability scanning often preferred?

(A) It is always faster

(B) It avoids all false positives

(C) It requires no credentials

(D) It provides deeper, more accurate results by inspecting configurations and installed software

Q89: Explanation

Correct Answer: D

- Credentials allow internal visibility.
- Fewer false negatives result.
- Credentials must be protected.

Key Takeaway

Authenticated scans see more.

Q90: Time Synchronization

Question

Logs from different systems cannot be correlated because their clocks differ. What is the **BEST** fix?

(A) Ignore times in logs

(B) Turn off logging

(C) Synchronize systems to a reliable time source

(D) Use different time zones deliberately

Q90: Explanation

Correct Answer: C

- Accurate timestamps are essential for investigation.
- Correlation depends on consistent time.
- Time services must be protected.

Key Takeaway

Correlation requires consistent clocks.

Q91: Cloud Identity Risk

Question

Cloud administrator accounts use only passwords. What is the **BEST** recommendation?

(A) Share the admin password

(B) Require multi-factor authentication, least privilege, and monitoring for administrative access

(C) Use long-lived keys in code

(D) Remove logging

Q91: Explanation

Correct Answer: B

- Admin accounts are high-value targets.
- MFA reduces compromise.
- Monitoring detects misuse.

Key Takeaway

Protect cloud admins most.

Q92: Secrets in Code

Question

Developers store passwords and API keys in source code. What is the **BEST** remedy?

(A) Keep secrets in code but hide the repository name

(B) Share secrets by chat

(C) Never rotate keys

(D) Use a secrets management solution, rotate exposed secrets, and scan code for credentials

Q92: Explanation

Correct Answer: D

- Secrets in code leak easily.
- Rotation limits exposure.
- Scanning prevents recurrence.

Key Takeaway

Keep secrets out of code.

Q93: Containers

Question

A company runs applications in containers. Which practice is **MOST** important for managing risk?

(A) Pull images from any source

(B) Use trusted images, scan for vulnerabilities, limit privileges, and secure orchestration

(C) Run all containers as root

(D) Ignore updates

Q93: Explanation

Correct Answer: B

- Image provenance reduces supply chain risk.
- Least privilege contains compromise.
- Orchestration security is crucial.

Key Takeaway

Trust, scan, limit.

Q94: Serverless Risk

Question

Which responsibility remains with the customer when using serverless functions?

(A) Secure code, permissions, and handling of data

(B) Physical servers

(C) Hypervisor patching

(D) Data center cooling

Q94: Explanation

Correct Answer: A

- Providers manage infrastructure.
- Customers control code and access.
- Misconfigured permissions are common issues.

Key Takeaway

Serverless still has code and permission risk.

Q95: Privacy by Design

Question

What does privacy by design mean?

(A) Building privacy protections into systems and processes from the start

(B) Adding privacy after launch

(C) Collecting maximum data

(D) Avoiding documentation

Q95: Explanation

Correct Answer: A

- Early design is more effective.
- It supports minimization and purpose limits.
- It reduces compliance costs.

Key Takeaway

Design privacy in, not on.

Q96: Pseudonymization

Question

How does pseudonymization differ from anonymization?

(A) They are identical

(B) Pseudonymized data can be re-identified with additional information, whereas properly anonymized data cannot reasonably be re-identified

(C) Anonymization is reversible by anyone

(D) Pseudonymization removes all data

Q96: Explanation

Correct Answer: B

- Pseudonyms reduce but do not remove privacy risk.
- Additional information must be protected.
- True anonymization is difficult.

Key Takeaway

Pseudonymized is not anonymous.

Q97: Chain of Custody

Question

Why is chain of custody important in digital forensics?

(A) It speeds up analysis

(B) It lowers costs

(C) It replaces backups

(D) It documents who handled evidence and when, preserving its integrity and admissibility

Q97: Explanation

Correct Answer: D

- Documentation shows evidence was not altered.
- Legal proceedings may depend on it.
- Procedures should be followed strictly.

Key Takeaway

Evidence needs a documented trail.

Q98: Capacity Management

Question

Which risk does poor capacity management **MOST** directly create?

(A) Excess privacy

(B) Performance degradation or outages when demand exceeds resources

(C) Better compliance

(D) Faster recovery

Q98: Explanation

Correct Answer: B

- Availability depends on adequate capacity.
- Trending usage supports planning.
- Cloud elasticity helps but needs oversight.

Key Takeaway

Plan capacity before demand outruns it.

Q99: IT Asset Disposal

Question

Retired laptops and drives are being sent for recycling. What is the **BEST** control?

(A) Delete visible files only

(B) Securely wipe or destroy storage media and keep disposal records

(C) Donate unwiped

(D) Store in an unlocked room

Q99: Explanation

Correct Answer: B

- Simple deletion leaves data recoverable.
- Records provide proof.
- Vendors should be verified.

Key Takeaway

Sanitize before disposal.

Q100: Security Misconfiguration Management

Question

Cloud and server configurations frequently drift from approved settings. What is the **BEST** control?

(A) Review configurations once every five years

(B) Trust administrators' memory

(C) Define secure baselines and use automated configuration monitoring with remediation workflows

(D) Disable monitoring

Q100: Explanation

Correct Answer: C

- Drift is a common cause of exposure.
- Automation detects deviations quickly.
- Workflows ensure fixes.

Key Takeaway

Baseline it, monitor it, fix the drift.

Exam Mindset Summary

Remember These Core Principles

- **Business First:** Risk is defined by its effect on business objectives.
- **Owners Decide:** Practitioners inform; owners accept, mitigate, transfer, or avoid.
- **Three Lines:** The first line owns risk, the second oversees, and the third gives independent assurance.
- **Ethics Matter:** Honesty, independence, and confidentiality underpin credible risk advice.
- **Evidence Over Opinion:** Use data, scenarios, and calibrated ratings.
- **Proportionality:** Controls should fit the risk and its cost.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.